

Laboratorio 1: Análisis de Seguridad

Introducción

En este laboratorio aplicarás el marco conceptual presentado en la primera clase para analizar la seguridad de diferentes sistemas. No escribirás código — el objetivo es desarrollar tu capacidad de pensar sistemáticamente sobre seguridad antes de implementar cualquier solución.

Recordemos el plan de alto nivel para pensar sobre seguridad:

- **Objetivo:** Lo que el sistema está tratando de lograr. Las categorías principales son:
 - *Confidencialidad:* No hay forma de que el adversario aprenda información secreta.
 - *Integridad:* No hay forma de que el adversario corrompa el estado del sistema.
 - *Disponibilidad:* El sistema sigue funcionando a pesar del adversario.
 - **Modelo de Amenaza:** Suposiciones sobre lo que el atacante puede y no puede hacer.
 - ¿Qué recursos tiene el atacante?
 - ¿Qué acceso tiene al sistema?
 - ¿Qué está fuera de alcance?
 - **Política:** El plan o conjunto de reglas que hará que el sistema logre el objetivo.
 - ¿Quién puede hacer qué?
 - ¿Bajo qué condiciones?
 - ¿Qué está prohibido?
 - **Mecanismo:** El software/hardware que el sistema usa para hacer cumplir la política.
 - ¿Cómo se implementa la política técnicamente?
 - ¿Qué tecnologías específicas se usan?
-

Instrucciones Generales

Para cada escenario presentado, debes escribir un análisis que incluya:

1. **Objetivo:** debes indicar el orden de importancia de confidencialidad, integridad y disponibilidad.
2. **Modelo de Amenaza:** mínimo 3 tipos de atacantes o vectores de ataque.
3. **Política:** mínimo 5 reglas concretas.
4. **Mecanismo:** mínimo 3 mecanismos técnicos que implementen las políticas.

Sé específico. No escribas generalidades como “el sistema debe ser seguro”. En cambio, escribe cosas como “solo el dueño de una cuenta puede ver su historial de compras” (política) o “las contraseñas deben hashear con bcrypt antes de almacenarse” (mecanismo).

Formato de entrega: Un archivo .md con tu análisis para cada escenario. Usa el template proporcionado al final de este documento.

Ejemplo Resuelto: Sistema de Notas de IIC2531

Contexto: El curso IIC2531 necesita almacenar las notas de los estudiantes en un servidor. Los ayudantes deben poder leer y escribir el archivo con las notas. Los estudiantes solo deberían poder ver sus propias notas.

Objetivo

Orden de prioridad: Integridad > Confidencialidad > Disponibilidad

- **Integridad:** Las notas no pueden ser modificadas por personas no autorizadas. Un estudiante no puede cambiar su propia nota ni la de otros.
- **Confidencialidad:** Un estudiante solo puede ver sus propias notas, no las de sus compañeros.
- **Disponibilidad:** El sistema debe estar disponible para consultas durante el semestre, especialmente cerca de fechas de entrega.

Justificación del orden: La integridad es lo más crítico porque notas incorrectas tienen consecuencias académicas graves. La confidencialidad importa por privacidad (FERPA/regulaciones locales). La disponibilidad es importante pero una caída temporal es tolerable — las notas pueden consultarse después.

Modelo de Amenaza

Atacantes Considerados

1. **Estudiante curioso:** Tiene cuenta en el sistema, motivado por ver notas de compañeros o mejorar las propias. Puede intentar manipular URLs, explotar bugs en la aplicación web, o hacer ingeniería social a los ayudantes.
2. **Atacante externo:** Sin cuenta en el sistema. Puede intentar explotar vulnerabilidades del servidor, interceptar tráfico de red, o realizar ataques de fuerza bruta contra contraseñas.
3. **Ayudante malicioso/comprometido:** Tiene acceso legítimo al archivo de notas. Podría modificar notas indebidamente o filtrar el archivo completo. Su laptop podría ser robada con una copia local.

Fuera de Alcance

- Ataques físicos al datacenter del DCC (asumimos seguridad física adecuada)
- Compromiso del sistema operativo del servidor (responsabilidad de TI)
- Coerción física a los ayudantes

Política

1. Solo los ayudantes autenticados pueden leer el archivo completo de notas.
2. Solo los ayudantes autenticados pueden modificar notas.
3. Los estudiantes autenticados pueden ver únicamente su propia nota.
4. Toda modificación de notas debe quedar registrada (quién, cuándo, qué cambió).
5. Las contraseñas de ayudantes deben tener mínimo 12 caracteres y no estar en listas de contraseñas filtradas.
6. Las sesiones expiran después de 30 minutos de inactividad.
7. El acceso al sistema requiere conexión desde la red universitaria o VPN.

Mecanismo

Política	Mecanismo
Solo ayudantes pueden leer/escribir	Control de acceso basado en roles (RBAC) en la aplicación; archivo de notas sin acceso directo por web
Estudiantes ven solo su nota	Consulta filtrada por RUT del usuario autenticado; nunca exponer lista completa
Registro de modificaciones	Log de auditoría append-only con timestamp, usuario, y diff del cambio
Contraseñas seguras	Validación contra HaveIBeenPwned API al crear contraseña; hash con Argon2
Sesiones expiran	Token JWT con expiración de 30 min; renovación requiere re-autenticación
Acceso desde red universitaria	Firewall que solo permite conexiones desde rangos IP de la universidad + VPN
Protección en tránsito	HTTPS obligatorio (TLS 1.3); HSTS habilitado

Análisis de Brechas

- **Laptop de ayudante robada:** La política actual no cubre copias locales. Posible mejora: prohibir descargas locales del archivo completo, o requerir cifrado de disco en laptops de ayudantes.
- **Ayudante malicioso:** El log de auditoría detecta cambios pero no los previene. Posible mejora: requerir aprobación de dos ayudantes para cambios de notas.
- **Ingeniería social:** No hay mecanismo técnico contra un ayudante que voluntariamente comparte su contraseña. Mitigación: capacitación + consecuencias disciplinarias (componente humano de la política).

Escenario 1: Tienda Online de Barrio

Contexto: Don Carlos tiene una ferretería en Providencia y quiere vender sus productos por internet. Tiene un catálogo de ~500 productos, espera 10-20 pedidos diarios, y quiere que los clientes puedan pagar con tarjeta de crédito o transferencia bancaria. Don Carlos administrará el sitio él mismo desde su computador en la tienda.

Consideraciones adicionales: - Los clientes deben poder crear cuentas para ver su historial de pedidos - Don Carlos necesita poder actualizar precios e inventario - El sitio debe mostrar si un producto está disponible o agotado - Los pedidos pueden ser con despacho a domicilio o retiro en tienda

Preguntas guía: - ¿Qué información es sensible en este sistema? - ¿Quiénes son los usuarios legítimos y qué necesitan hacer? - ¿Qué pasa si un atacante obtiene acceso al panel de administración? - ¿Qué pasa si un atacante puede modificar los precios? - ¿Cómo afecta que Don Carlos no sea experto en tecnología?

Escenario 2: Marketplace de Retail

Contexto: MegaStore es una cadena de retail que opera en 5 países de Latinoamérica. Su plataforma e-commerce procesa 50,000 transacciones diarias, tiene 2 millones de usuarios registrados, y permite que vendedores externos (marketplace) publiquen productos junto al inventario propio de MegaStore. La empresa tiene un equipo de 20 desarrolladores y un equipo de seguridad de 3 personas.

Consideraciones adicionales: - Los vendedores del marketplace reciben pagos semanales por sus ventas - Existe un programa de puntos/fidelización para clientes frecuentes - La plataforma tiene una app móvil además del sitio web - Hay un call center que puede acceder a información de clientes para resolver problemas - Se integra con múltiples proveedores de pago y empresas de logística

Preguntas guía: - ¿Cómo difiere el modelo de amenaza respecto al Escenario 1? - ¿Qué nuevos actores (vendedores, call center) introducen nuevos riesgos? - ¿Qué pasa si un vendedor del marketplace es malicioso? - ¿Cómo se protege el dinero de los vendedores legítimos? - ¿Qué información puede ver el call center y qué no debería poder ver? - ¿Cómo afecta la escala al modelo de amenaza?

Escenario 3: Portal de Gobierno

Contexto: El Servicio de Registro Civil necesita un portal donde los ciudadanos puedan: - Descargar certificados de nacimiento, matrimonio y defunción - Actualizar su dirección registrada - Solicitar hora para trámites presenciales - Consultar el estado de trámites en curso

El portal debe integrarse con ClaveÚnica (el sistema de autenticación del gobierno chileno). Aproximadamente 100,000 ciudadanos usan el portal mensualmente.

Consideraciones adicionales: - Los certificados tienen validez legal y pueden usarse para trámites bancarios, notariales, etc. - Existe información sensible como estado civil, filiación, y datos de menores de edad - Algunos trámites requieren pago de aranceles - Los funcionarios del Registro Civil deben poder procesar solicitudes y emitir documentos - El sistema debe cumplir con la Ley de Protección de Datos Personales

Preguntas guía: - ¿Qué hace diferente la seguridad de un sistema gubernamental? - ¿Qué consecuencias tiene la emisión de un certificado fraudulento? - ¿Cómo se verifica que quien solicita un certificado tiene derecho a obtenerlo? - ¿Qué información debería poder ver un funcionario vs. un ciudadano? - ¿Cómo se auditan las acciones de los funcionarios? - ¿Qué pasa si ClaveÚnica es comprometida?

Escenario 4: Sistema de Votación Estudiantil

Contexto: El Centro de Alumnos de Ingeniería (CAi) necesita un sistema de votación online para las elecciones anuales. Participan aproximadamente 1,500 estudiantes habilitados para votar, y la votación estará abierta por 48 horas. Hay 4 listas compitiendo. El proceso es administrado por un Tricel (Tribunal Calificador de Elecciones) compuesto por 3 estudiantes.

Consideraciones adicionales: - Solo pueden votar estudiantes con matrícula vigente en Ingeniería - Cada estudiante puede votar exactamente una vez - El voto debe ser secreto (nadie puede saber por quién votó un estudiante específico) - Los resultados deben ser verificables y transparentes una vez cerrada la votación - El Tricel tiene acceso administrativo al sistema para resolver problemas técnicos - Los candidatos y sus apoderados quieren asegurarse de que el proceso sea justo

Preguntas guía: - ¿Cómo se verifica que alguien es estudiante habilitado sin comprometer el secreto del voto? - ¿Qué pasa si un miembro del Tricel quiere favorecer a una lista? - ¿Cómo pueden los candidatos verificar que los resultados son correctos? - ¿Qué pasa si el sistema cae durante las 48 horas de votación? - ¿Es posible demostrar que votaste de cierta manera? ¿Eso es bueno o malo? - ¿Cómo se diferencia este sistema de uno de encuestas anónimas?

Escenario 5: Cajero Automático (ATM)

Contexto: Un banco necesita diseñar la seguridad de sus cajeros automáticos. Cada ATM está ubicado en un lugar público (mall, estación de metro, sucursal), opera 24/7, y se conecta a los servidores del banco a través de una red privada. Los clientes pueden retirar efectivo, consultar saldo, y hacer transferencias usando su tarjeta y PIN.

Consideraciones adicionales: - El cajero contiene efectivo físico (típicamente \$10-30 millones CLP) - Componentes de hardware: lector de tarjetas, teclado PIN, dispensador de billetes, impresora de comprobantes, cámara - Una empresa externa se encarga del mantenimiento y la carga de efectivo - El cajero debe seguir operando si pierde conexión temporalmente con el banco - Los clientes esperan que sus transacciones se reflejen inmediatamente en su cuenta

Preguntas guía: - ¿Qué es más valioso para un atacante: el efectivo dentro del cajero o los datos de las tarjetas? - ¿Cómo se asegura el banco de que el técnico de mantenimiento no robe efectivo o instale un skimmer? - ¿Qué pasa si alguien instala un dispositivo falso sobre el lector de tarjetas? - ¿Cómo debería comportarse el cajero si pierde conexión con el banco a mitad de una transacción? - ¿Qué información debe guardar el cajero localmente y cuál nunca debería almacenar? - ¿Cómo se protege el PIN durante todo el proceso (teclado → cajero → banco)? - ¿Qué ataques físicos existen y cómo se mitigan?

Escenario 6: Tu Propio Escenario

Instrucciones: Elige un sistema real que uses frecuentemente (puede ser una app, un servicio web, un sistema de tu trabajo, etc.) y realiza el mismo análisis. El sistema debe ser suficientemente complejo como para tener múltiples tipos de usuarios y datos sensibles.

Ejemplos de sistemas válidos: - Sistema de gestión académica (ej: SIDING, UCampus) - Aplicación de banco o fintech - Red social o servicio de mensajería - Sistema de salud (agenda médica, resultados de exámenes) - Plataforma de streaming o gaming

Nota: Si eliges un sistema de tu trabajo, puedes anonimizar nombres y detalles específicos, pero mantén la estructura y complejidad real.

Entrega

Fecha de entrega: 18 de Marzo de 2026

Formato: un archivo .md con el contenido

Template de Respuesta

Escenario N: [Nombre]

Objetivo

Orden de prioridad: [Integridad/Confidencialidad/Disponibilidad] > [...] > [...]

- **[Primera prioridad]**: [Por qué es lo más importante]
- **[Segunda prioridad]**: [Por qué importa]
- **[Tercera prioridad]**: [Por qué es menos crítico]

Justificación del orden: [Explicar por qué ordenaste así]

Modelo de Amenaza

Atacantes Considerados

1. [Tipo de atacante 1]: [Capacidades y motivación]
2. [Tipo de atacante 2]: [Capacidades y motivación]
3. [Tipo de atacante 3]: [Capacidades y motivación]

Fuera de Alcance
- [Qué ataques NO consideramos y por qué]

Política

1. [Regla 1]
2. [Regla 2]
3. [Regla 3]
4. [Regla 4]
5. [Regla 5]

Mecanismo

Política	Mecanismo
-----	-----
[Regla 1]	[Tecnología/proceso que la implementa]
[Regla 2]	[Tecnología/proceso que la implementa]
...	...

Análisis de Brechas (Opcional)

[¿Hay políticas sin mecanismo claro? ¿Hay ataques en el modelo de amenaza que no están cubiertos por ninguna política?]

Recursos Adicionales

- Lectura de clase: Introducción a Seguridad Computacional
 - OWASP Top 10: <https://owasp.org/www-project-top-ten/>
 - STRIDE Threat Model: <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats>
-